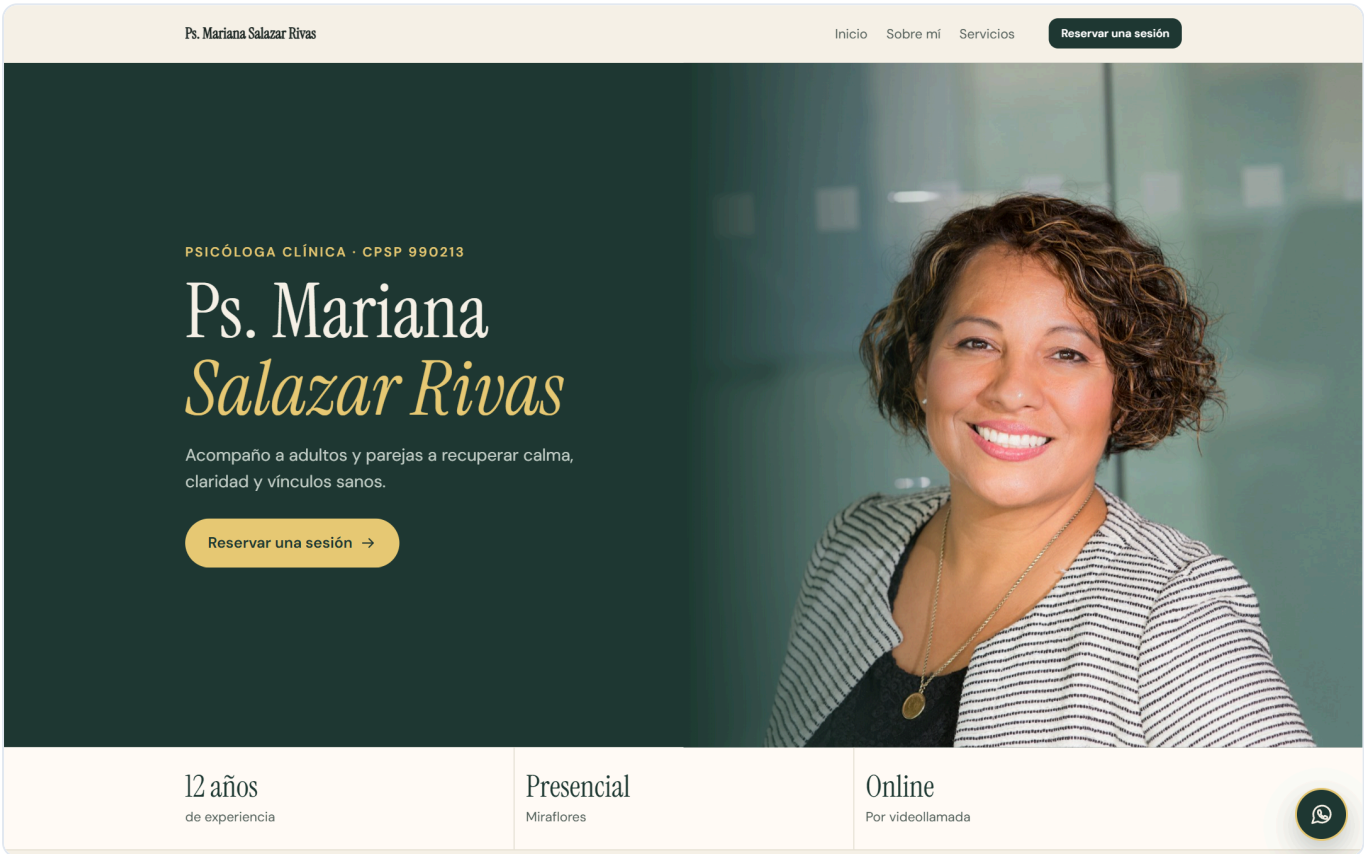
CASO DE ESTUDIO · SAAS DE SALUD · 2026

# Agenda, pacientes y cobros para psicólogos independientes

Aplicación web por suscripción para varios consultorios, cada uno con sus datos separados. Cada psicóloga tiene su página pública, sus pacientes reservan sin crear cuenta y ella maneja agenda, pacientes, pagos y reportes desde el celular. Pensada para cuidar la privacidad de datos de salud mental.

Next.js 16 · React 19 · TypeScript · PostgreSQL 17 · Supabase autoalojado · RLS: datos separados · Docker · Playwright




AUTOR
**Bryan Jeremy Espinoza Herrera**
BJOTA Systems · Perú

ESTADO
**Listo en ensayo de producción**
despliegue en VPS pendiente

DESARROLLO
**Ago. – oct. 2026**
177 commits

## 01 Resumen

Muchas psicólogas independientes llevan su consulta con WhatsApp, cuadernos y memoria. Los comprobantes llegan por chat, los cambios de horario se conversan y no queda claro quién pagó y quién debe. Construí una **aplicación web para varios consultorios**. Cada profesional tiene su propia página pública, recibe solicitudes de cita que acepta con un toque y lleva agenda, pacientes, cobros y reportes en un solo lugar. Como son datos de salud mental, cuidar la privacidad y separar los datos de cada consultorio fueron requisitos desde el primer día.

**3116**
pruebas automáticas con Vitest

**436**
pruebas E2E con Playwright (un robot que usa la app)

**87**
migraciones: cambios a la base guardados por versiones

**21/21**
pruebas de ataque a permisos

## 02 El problema

**Citas por WhatsApp**
Responder "¿tienes horario?" entre sesiones. Los cambios de cita se pierden en el chat.

**Cobros sin control**
Comprobantes de transferencia sueltos. Sesiones atendidas que nadie recuerda si se pagaron.

**Sin presencia profesional**
Muchas psicólogas no tienen una página donde mostrar enfoque, formación y precios.

**Datos sensibles mal guardados**
Información de pacientes en cuadernos y conversaciones sin ninguna protección.

## 03 La solución

**Página profesional**
Perfil con enfoque, temas, servicios, formación, ubicación y preguntas frecuentes. Ella lo edita por partes.

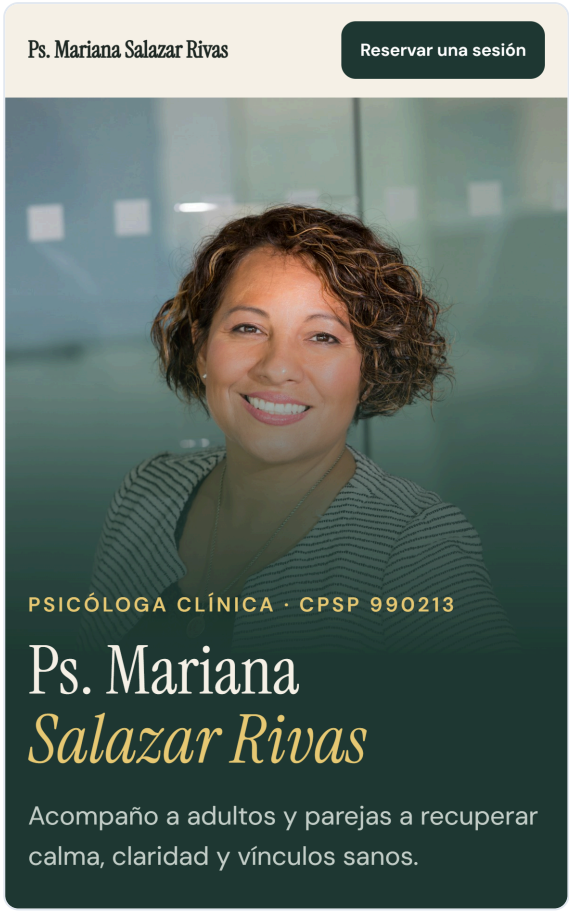
**Reserva sin cuenta**
El paciente elige servicio, día y hora. La profesional acepta o rechaza la solicitud.

**Consulta ordenada**
Agenda del día y de la semana, pacientes, cobros con comprobante, mensajes de WhatsApp ya escritos y reportes.

# 04 La página pública de la profesional




Página del perfil de demostración «Ps. Mariana Salazar Rivas» (persona ficticia).

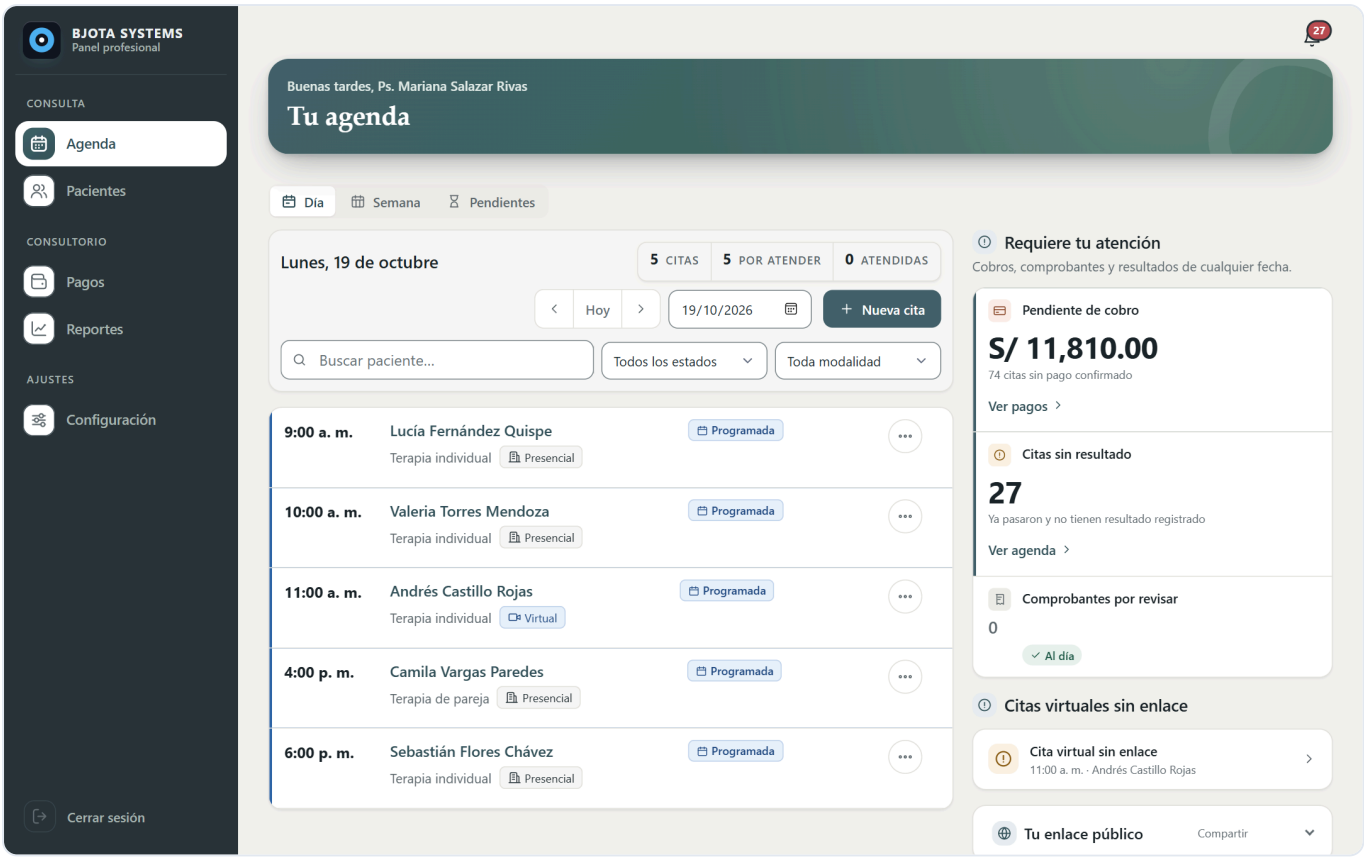



Vista en el celular.

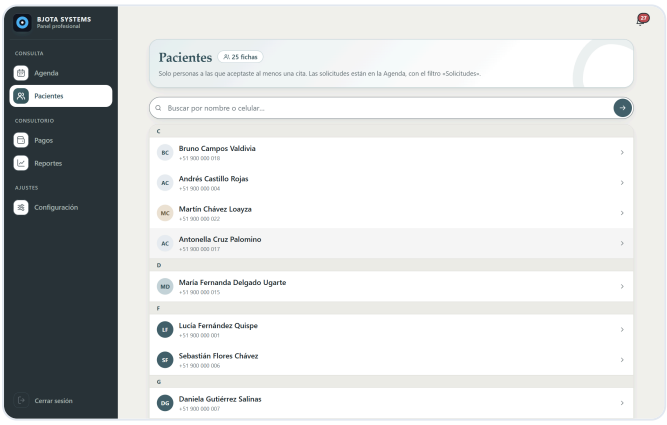



Reserva en 4 pasos, sin crear cuenta.

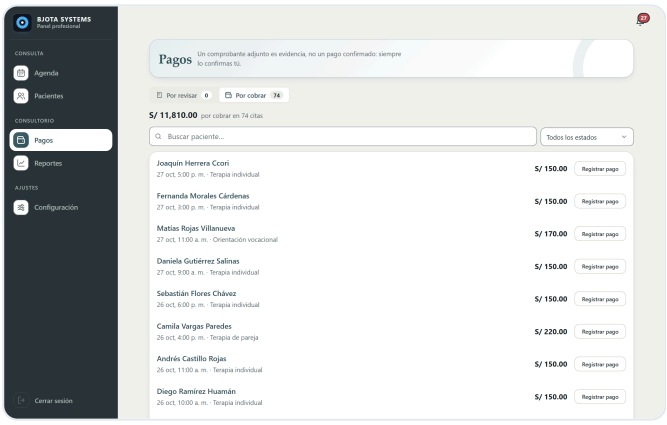
# 05 El panel de la psicóloga




Agenda del día, con lo que necesita atención: cobros pendientes, citas sin marcar y comprobantes por revisar.

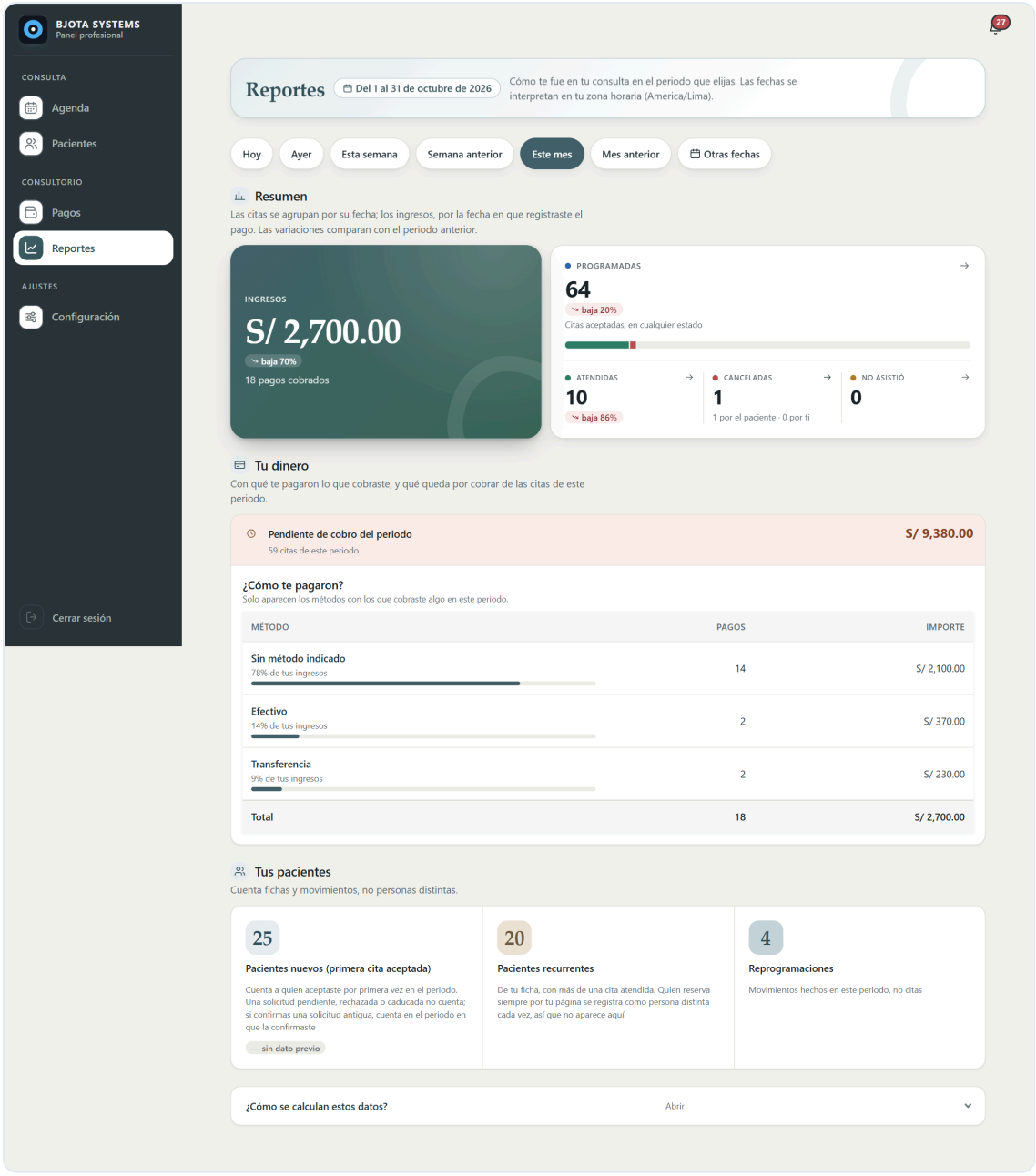



Pacientes: solo datos para agendar y cobrar, sin historia clínica (se guarda lo mínimo a propósito).

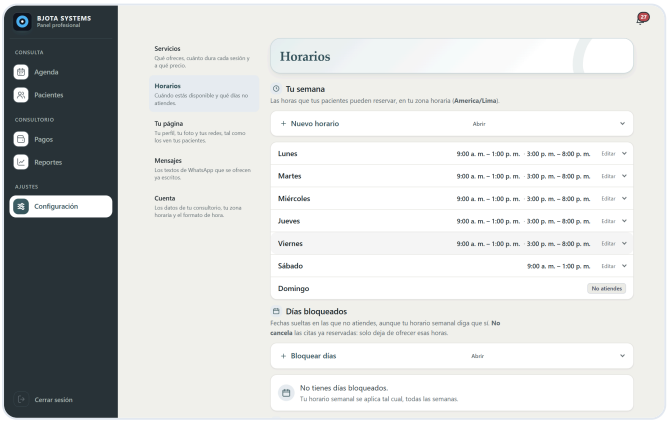



Pagos por cobrar y comprobantes por revisar.

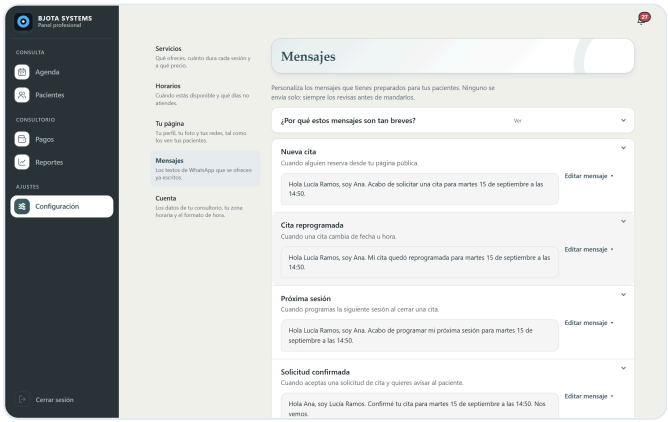
# 06 Reportes y configuración




Reportes del mes: ingresos, citas programadas y atendidas, inasistencias y cobros por método.

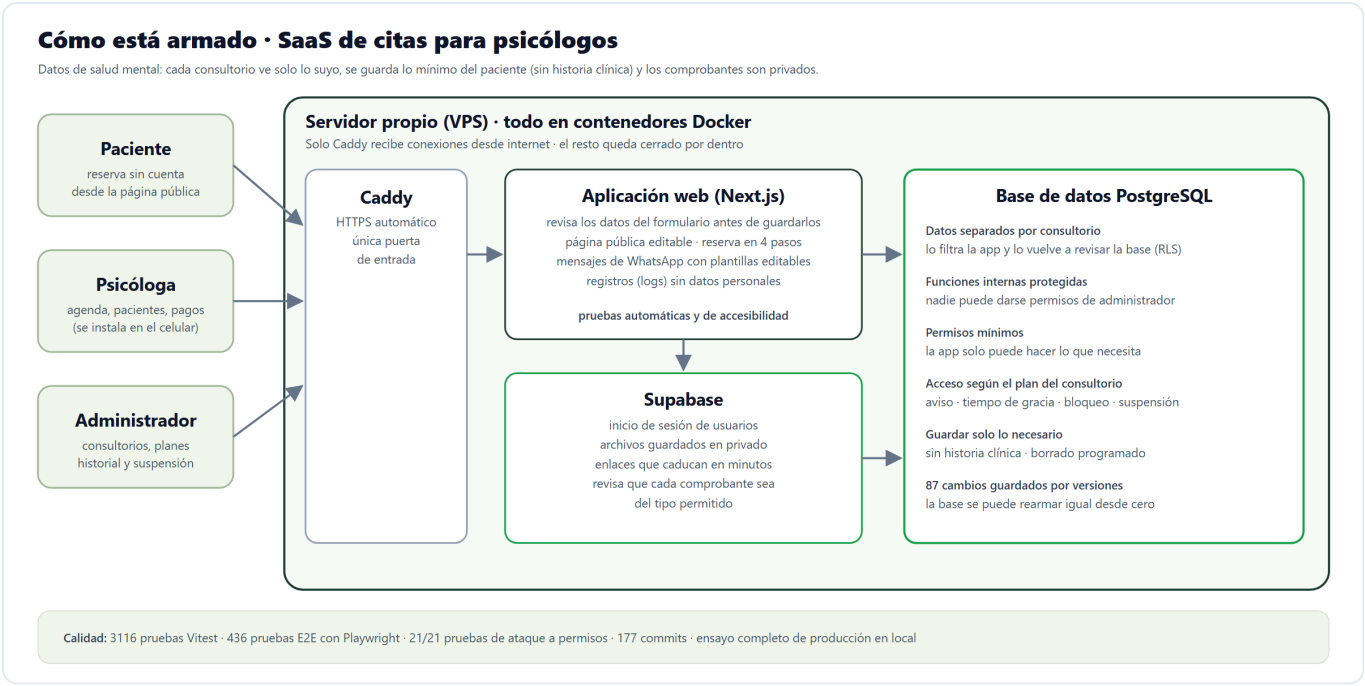



Horario semanal con pausas y días bloqueados.




Plantillas de WhatsApp editables (se envían desde su propio número).

# 07 Cómo está armado




## Decisiones principales

| Decisión | Por qué |
|---|---|
| **Datos separados con doble control** | La aplicación filtra los datos de cada consultorio. Además, la base de datos PostgreSQL lo vuelve a revisar con RLS: reglas dentro de la base que hacen que cada consultorio vea solo lo suyo. Lo comprobé con 17 pruebas en una base de datos real. |
| **Guardar solo lo necesario** | No se guardan historia clínica, notas ni diagnósticos. Solo lo que hace falta para agendar y cobrar (minimización de datos, en la línea de la Ley 29733). Lo que no se guarda no se puede filtrar. |
| **Solicitud, no reserva automática** | La cita del paciente llega como solicitud y la profesional la acepta. Así cuida su agenda y evita abusos. |
| **Comprobantes privados** | Se guardan en un espacio privado. Al subirlos se revisa que el archivo sea de verdad del tipo permitido y no otro archivo disfrazado. Para verlos se usan enlaces que caducan en pocos minutos. |
| **Servidor propio** | La base de datos, el inicio de sesión, los archivos y la aplicación corren en contenedores Docker en un servidor propio. Caddy es la única puerta de entrada desde internet y pone HTTPS automático. Así los datos quedan bajo mi control. |
| **Acceso por consultorio** | Planes con aviso, tiempo de gracia, bloqueo y suspensión. Lo aplica la base de datos, no solo la pantalla. |

## 08 Seguridad: un fallo real encontrado y corregido

**Hallazgo:** en una revisión de seguridad encontré que una función de la base de datos estaba mal configurada y podía permitir que un usuario se diera permisos de administrador (esto se llama escalada de privilegios). Lo corregí y agregué una prueba automática para que no vuelva a pasar.

- **Permisos mínimos:** quité a la aplicación los permisos de la base de datos que no necesitaba. Lo comprobé con 21 de 21 pruebas de ataque a permisos que pasan.
- **Registros sin datos personales:** los registros del sistema (logs) ocultan datos personales y contraseñas. Hay 33 pruebas que lo revisan.
- **Enlaces de un solo uso:** cuando la psicóloga propone otro horario, el paciente recibe un enlace que caduca en 48 h.
- **Medir, no suponer:** medí que el límite de intentos de inicio de sesión era muy alto y lo dejé documentado para reforzarlo.
- **Riesgos documentados:** análisis de riesgos de seguridad documentado y clasificación de qué datos son sensibles. El borrado programado de datos viejos está en modo de prueba.
- **Accesibilidad:** pruebas automáticas de accesibilidad en las pantallas principales.

## 09 Estado del proyecto

- **Funciona y está probado:** toda la primera versión corre en un **ensayo completo de producción en mi computadora**, con los mismos contenedores que irán al VPS (servidor alquilado en internet) y con HTTPS. Pasa sus 26 de 26 revisiones de mantenimiento.
- **Siguiente paso:** subirlo al VPS con dominio y certificados reales, activar correos automáticos y definir la política de copias de seguridad (backups) antes de recibir datos reales.
- **Fuera de esta versión a propósito:** pagos en línea, recordatorios automáticos y que el paciente gestione sus propias citas.

## 10 Lo que aprendí

- **La seguridad se prueba atacando.** No habría encontrado el fallo de permisos de administrador sin probar a atacar mi propio sistema. Ahora esa prueba se ejecuta siempre.
- **Con datos de salud, menos es más.** Decidir qué no guardar fue tan importante como decidir qué construir.
- **Ensayar antes de publicar.** Armar todo el sistema de producción en mi computadora, con copias de seguridad y su restauración, baja el riesgo de la primera puesta en marcha real.
- **Probar como el usuario.** 436 pruebas E2E con Playwright recorren lo que de verdad hacen la psicóloga y el paciente, incluida la accesibilidad.
- **IA como herramienta, con orden.** Desarrollé con apoyo de asistentes de IA siguiendo un plan general, planes por etapa y revisiones al terminar cada una.

## 11 Mi rol

Proyecto propio de principio a fin. Definí qué necesitaba el producto junto con una psicóloga piloto. Diseñé cómo se guardan los datos, cómo se conectan las partes y cómo se protege la privacidad. Desarrollé la aplicación con apoyo de asistentes de IA. Preparé las pruebas (automáticas, de ataque a permisos y E2E) y el servidor propio con Docker.

---

Todas las capturas son de una copia local con la cuenta de demostración «Ps. Mariana Salazar Rivas»: persona, pacientes y teléfonos ficticios; foto de Unsplash (Christina @ wocintechchat). No se publican el código fuente, datos reales ni claves del servidor.

Bryan Jeremy Espinoza Herrera · BJOTA Systems · 2026